

AI Assessment Pathway: study guide

How the tenth tool of the Privacy & AI Assessment works, which assessment to use when, and the frameworks behind it. Built from the shipped tool (assessment.new.js), 18 steps and 101 questions. Reference material, not legal advice.

Contents

1. AI risk assessment and generative AI risk assessment
2. Which assessment for which case, and in what order
3. The benchmarks
4. How the pathway works
5. The EU AI Act module
6. The impact level
7. Framework coverage and how to read it
8. Worked examples
9. Every question in the pathway
10. Practice questions
11. Sources

1. AI risk assessment and generative AI risk assessment

Both assess an AI system before and during use. They differ in what they look for, how they test it and who has to act.

	AI risk assessment	Generative AI risk assessment
Scope	Any AI system: a scoring model, a classifier, a recommender, a rules engine that infers, an agent. The question is what the system decides or influences and for whom.	Systems that generate text, images, audio, video or code, or run on a foundation model. The question is what the model can be made to produce or do, and what flows through its prompts.
Typical risks	Wrong or biased decisions about people, opacity, over-reliance, data quality, function creep, legal classification (prohibited, high-risk).	Confabulation, prompt injection, data leakage through prompts or retrieval, harmful or infringing content, excessive agency, supply chain of models and plug-ins, unbounded cost.
Testing	Accuracy against a threshold on representative data, error rates and outcomes across groups, drift monitoring, human review of individual decisions.	Red-teaming and adversarial testing, injection tests on every change, output filters tested in both directions, grounding and citation checks, threat modelling against MITRE ATLAS.
Who is responsible	The deployer for the use and its effects; the provider for the system's design and documentation; under the EU AI Act both have duties that depend on the risk class.	The same split, plus the provider of the general-purpose model upstream, whose documentation and terms the deployer depends on and whose duties sit in Articles 53 to 55 of the AI Act.
Reference frameworks	NIST AI RMF 1.0, ISO/IEC 42001, ISO/IEC 42005, EU AI Act.	NIST AI 600-1, OWASP Top 10 for LLM Applications, MITRE ATLAS, the Singapore framework for generative AI, EU AI Act Article 50.

A generative system needs both. A chatbot that answers benefit questions is a generative system and, if it shapes decisions about eligibility, an AI system with effects on people. That is why the pathway runs the core and impact steps for every system and adds the generative AI module on top, rather than choosing one.

2. Which assessment for which case, and in what order

Case	Start with	Then	Why
A new AI system, any kind, not yet assessed	AI Assessment Pathway	The handovers it offers	One intake, the impact level decides the depth, the modules open only if they apply.
Only the EU AI Act classification is needed, quickly	AI Risk Assessment	The pathway when the system goes ahead	The standalone tool screens the prohibited and high-risk gates with business factors; it does not screen Article 50 or GPAI.
A technical security review of an LLM application	Generative AI Risk Assessment	The pathway for the organisational view	Same checks as the pathway's GenAI module, without intake or governance.
A deployer that is a public body, or uses credit scoring or life and health insurance pricing, on an Annex III system	AI Assessment Pathway	FRIA from the pathway result, then the Full DPIA	Article 27 applies; the FRIA starts with most answers filled. The DPIA covers the processing.
Personal data in the system	AI Assessment Pathway	Full DPIA from the pathway result (or the Privacy Assessment first if a DPIA may not be needed)	Whether a DPIA is required turns on Article 35(3), which the DPIA asks first.
The model or service comes from a vendor	Third-Party Security Assessment with its AI/ML supplement	Transfer Impact Assessment if data leaves the EEA	Vendor controls and transfers are separate assessments with their own owners.
Something has gone wrong	Incident & Breach Severity	Reassess in the pathway (an incident is a reassessment trigger)	Severity of a breach is a different question from the risk of the system.

The order follows a rule: settle what the system is and what applies before rating it in depth. The pathway does the first part for every AI system and hands over to the specialist tools for the second.

3. The benchmarks

Six benchmarks in seven documents; NIST AI 600-1 is a profile of the AI RMF. Only the EU AI Act is law. The pathway uses each for one job, and its mapping to all of them is its own.

Benchmark	What it is	Best for	Legal or voluntary	How the pathway uses it
NIST AI RMF 1.0 (NIST AI 100-1, January 2023)	A risk management framework in four functions, Govern, Map, Measure, Manage, broken into categories and subcategories.	A common vocabulary for AI risk activities across an organisation.	Voluntary. NIST has announced a revision; none published as of October 2026.	Every question is mapped to subcategories; a coverage table by subcategory.
NIST AI 600-1 (Generative AI Profile, July 2024)	Twelve risks specific to or made worse by generative AI, with suggested actions.	Naming the generative risks a system is exposed to.	Voluntary.	The GenAI module's checks map to the twelve risks; a coverage table.
Government of Canada Algorithmic Impact Assessment	A scored questionnaire under the Directive on Automated Decision-Making that gives impact levels I to IV, each level carrying more requirements.	Setting how much scrutiny a system needs before it is used.	Mandatory for Canadian federal institutions; a method model elsewhere.	Method only: the impact level is a weighted score banded at 25, 50 and 75 percent. Questions and weights are the pathway's own.
ISO/IEC 42005:2025	Guidance on AI system impact assessment: scope, timing, affected parties, analysis, recording and approval.	How to run an impact assessment.	Voluntary standard (paid text).	Cited as method for the Impact step; the step asks for effects on individuals, groups and society.
ISO/IEC 42001:2023	Requirements for an AI management system, with Annex A controls.	Running AI governance as a certifiable management system.	Voluntary standard (paid text).	Governance fields and a coverage column only, clauses and controls cited by number and title. No ISO-specific questions.
Singapore Model AI Governance Framework for Generative AI (May 2024)	Nine dimensions for a trusted generative AI ecosystem: accountability, data, trusted development and deployment, incident reporting, testing and assurance, security, content provenance, safety and alignment R&D, AI for public good.	A balanced checklist across organisation and ecosystem.	Framework, not law; addressed to policymakers, industry, researchers and the public.	A coverage table for generative systems. Dimensions 8 and 9 are mostly for governments and model developers and usually stay Not assessed.
EU AI Act (Regulation (EU) 2024/1689 as amended by 2026/1744), including the FRIA of Article 27	Binding rules by risk class and role: prohibitions, high-risk requirements, transparency duties, general-purpose AI model duties, AI literacy.	Knowing what is legally required, of whom, and from when.	Law.	The AI Act module: classification and the obligations for your role, each linked to the AI Act Digest and the crosswalk. The FRIA by handover.

4. How the pathway works

Seven parts, in this order. Each fact is asked once, and every risk has one owner.

Part	Steps	Questions	Shown
Intake	3	15	always
Triggers	1	4	always
Core	2	13	always; three at levels III and IV only
Impact	1	12	always; six at levels III and IV only
Generative AI module	6	24	a generative AI trigger is Yes
EU AI Act module	4	23	the EU trigger is Yes or Not sure
Governance	1	10	always; two at levels III and IV only

Intake. Name and description, lifecycle, vendor and model, first use, the use area (Annex III), who is affected and whether any are vulnerable, how many, whether the output decides about people, whether a wrong output can be reversed, who uses the system, what data it handles, how autonomous it is and when a human acts. The impact level is worked out from these answers.

Triggers. Four questions: does it generate content, does it run on a foundation model, can users prompt it freely, is there an EU nexus under Article 2(1). Two more triggers are read from the intake: personal data (which offers the DPIA) and output that reaches people without review.

Core. Oversight and its competence, automation bias, training on the system's limits (which is also the Article 4 literacy measure), unequal outcomes across groups, logging, third-party data, whether the provider keeps or trains on your inputs, access to sensitive systems, multi-agent chains, business-critical data and exposure to competitors.

Impact. Harms, the rights engaged, effects beyond individuals, the provider's documentation, severity and likelihood before and after the measures on the same matrix as the Full DPIA, the measures, what happens when a risk materialises, complaints and explanation. These are the FRIA's own questions.

Generative AI module. The Generative AI Risk Assessment's questions minus those already asked: patterns and model, prompts and injection, leakage, retrieval permissions, intellectual property, output handling, grounding, content filters, agents and approval, provenance, training data, consumption, red-teaming, threat model, bias in generated content, monitoring and energy.

EU AI Act module. Role, prohibited practices, high-risk classification with Article 6(3), the general-purpose AI model duties and Article 50 transparency. Section 5.

Governance. Owner, assessor, approver, decision and its conditions, evidence, legal review, a route to suspend and report, the review date and the events that bring the assessment back early.

The result. An overall level from the worst finding, the impact level with its factor points, the AI Act classification, the handovers, one risk register and the obligations for your role, then the coverage tables. Findings on the same question merge into one line at the higher severity, tagged with the part that owns the question and any other part that raised it, and listed against every framework entry its questions map to.

Handovers. The FRIA is offered when a deployer uses an Annex III high-risk system and Article 27 applies or may apply. The answers carry under the same question ids, so the FRIA asks only what is left: period and frequency of use, reuse of an earlier assessment, notification. The Full DPIA is offered when personal data is involved; it receives the name, description, date, harms, special category data, processors, review date and the Article 35(3) criteria the answers already imply, and leaves severity and likelihood for the assessor, because the DPIA rates harm from the processing rather than interference with rights.

5. The EU AI Act module

Opened when the system is placed on the EU market or put into service there, used in the EU, or its output is used in the EU (Article 2(1)); "Not sure" opens it too. Article 2 excludes military, defence and national security uses, scientific research, testing before placing on the market, purely personal use, and free and open-source systems unless they are high-risk or caught by Article 5 or 50. Dates follow the Regulation as amended by Regulation (EU) 2026/1744.

Topic	What the module asks	What follows	Applies from
Roles (Article 3)	Provider, deployer, importer, distributor, product manufacturer, provider of a general-purpose AI model; several can apply.	Obligations are listed per role. A deployer using the system outside its intended purpose may become its provider (Article 25(1)).	with the obligations below
AI literacy (Article 4)	Read from the Core question on training users on the system's limits.	Always listed. The duty is to take measures to support literacy; no individual level has to be guaranteed.	2 February 2025
Prohibited practices (Article 5)	One question listing the practices.	Yes ends the module with Prohibited practice at the top of the result. Unsure leaves the classification unresolved.	2 February 2025; points (ba) and (bb), intimate imagery and child sexual abuse material, from 2 December 2026
High risk (Article 6)	The Annex I product route; the Annex III area from the intake; for Annex III, whether one of the four Article 6(3) conditions applies and whether the system profiles people; for a provider relying on 6(3), whether the assessment is documented and registered.	Profiling always keeps an Annex III system high-risk. Provider and deployer obligations listed with their dates and crosswalk rows.	2 December 2027 (Annex III); 2 August 2028 (Annex I)
Deployers of Annex III systems (Articles 26, 27, 86)	Deployer type, intended purpose, whether people are told.	Use per instructions with assigned oversight, input data, monitoring and suspension, workers' representatives and information to people, registration for public authorities, the FRIA where Article 27 applies, explanation on request.	2 December 2027
General-purpose AI models (Articles 51 to 55)	Systemic risk (presumed above 10^{25} FLOP or designated), open-source release, provider outside the EU, documentation, copyright policy, training content summary, authorised representative; with systemic risk, evaluation, incidents and cybersecurity.	Open-source models without systemic risk are relieved of the two documentation duties and the representative. Notification within two weeks once the threshold is met.	2 August 2025; models already on the market by 2 August 2027
Transparency (Article 50)	Direct interaction with people (read from the patterns where possible), synthetic content (from the trigger), emotion recognition or biometric categorisation, deep fakes and public-interest text, and whether the measures are in place.	Provider duties (inform people they interact with AI, machine-readable marking) and deployer duties (inform people exposed, disclose deep fakes and AI text on matters of public interest) listed by role.	2 August 2026; marking for generators already on the market by 2 December 2026 (Article 111(4))

Each obligation on the result links to its article in the AI Act Digest and its row in the AI Governance Crosswalk, where the ISO/IEC 42001 and NIST AI RMF mappings for that obligation are set out.

6. The impact level

The impact level follows the method of the Canadian Algorithmic Impact Assessment: a raw score from weighted answers, as a share of the maximum, banded into four levels. Level I up to 25 percent, II up to 50, III up to 75, IV above. The factors and weights are the pathway's own, and every factor is an intake answer.

Factor	Question	Answer: points	Max
Effect of the output on people	aipDecisionEffect	No decisions about people: 0; Supports decisions with minor effects on people: 1; Supports decisions with legal or similarly significant effects on people: 3; Makes decisions with legal or similarly significant effects on its own: 4; Not sure: 3	4
Reversibility of a wrong output	aipReversibility	Easily, and quickly: 0; With effort, or after some time: 2; Not, or only with great difficulty: 4; Not applicable: its output has no effect on people: 0; Not sure: 2	4
Number of people affected each year	affectedScale	Fewer than 100: 0; 100 to 10,000: 1; 10,000 to 1 million: 2; More than 1 million: 3	3
People in a vulnerable situation	friaVulnerable	none (left blank): 0; Children: 3; Elderly people: 2; Persons with disabilities: 2; People in financial hardship: 2; People in a dependent position (employees, detainees, asylum seekers): 2; Minority or under-represented groups: 2; Other: 2	3
Actions taken without human approval	autonomyLevel	None - a human approves every action: 0; Low-impact actions only: 1; Broad autonomous action: 3	3
When a human acts on an individual case	oversightMode	Before every decision takes effect: 0; On flagged or contested cases only: 1; After the fact, by sampling: 2; No human review: 3	3
Use area (Annex III)	annexIIIArea	1. Biometrics (remote identification, categorisation, emotion recognition): 4; 2. Critical infrastructure (safety components): 3; 3. Education and vocational training: 3; 4. Employment, workers' management and access to self-employment: 3; 5(a). Eligibility for public assistance benefits and services: 3; 5(b). Creditworthiness or credit scoring of natural persons (not fraud detection): 3; 5(c). Risk assessment and pricing in life and health insurance: 3; 5(d). Emergency call evaluation, dispatch and patient triage: 3; 6. Law enforcement: 4; 7. Migration, asylum and border control: 4; 8. Administration of justice and democratic processes: 4; Not an Annex III high-risk system: 0; Not sure: 2	4
Who uses it	gaiUsers	Staff only: 0; Selected business partners: 1; The public: 2	2
Sensitivity of the data	gaiPromptData	Personal data: 2; Special category data: 3; Confidential business information: 1; Source code or credentials: 1; None of these: 0	3

Maximum 29 points. In raw points: level I up to 7, II 8 to 14, III 15 to 21, IV 22 and above.

Floors. A use in an Annex III area, or a system that makes decisions with legal or similarly significant effects on its own, is never below level III, whatever the score. Without the first, a small Annex III use with good oversight would skip the rights, complaint and explanation questions that Articles 27 and 86 depend on.

Departures from the Canadian method. No mitigation deduction: the level is set before the mitigations are asked, and they show in the residual rating instead. Unanswered factors count as zero and the result says the level is provisional and names them.

Level	Meaning	What it changes in the pathway
I	Little to no impact: effects on people are brief and easily reversed.	Short Core, Impact and Governance; GenAI without the five depth questions unless the system is public-facing.
II	Moderate impact: effects are likely reversible and short-term.	As level I.
III	High impact: effects are difficult to reverse and may be ongoing.	Adds business-critical data, competitor exposure and automation bias (Core); rights, effects beyond individuals, provider information, when a risk materialises, complaints and explanation (Impact); input filtering, vector store, rate limits, threat model, energy (GenAI); evidence and a suspension route (Governance). A finding where a significant decision has no human making the final call.
IV	Very high impact: effects may be irreversible and lasting.	As level III, and a missing approver becomes a high finding: the decision belongs at the most senior level that owns the risk (NIST AI RMF GOVERN 2.3).

7. Framework coverage and how to read it

Each table lists every entry the pathway's questions map to. A row is **Gap** (with the worst severity) if a question mapped to it carries a finding, **Addressed** if a mapped question was answered without one, and **Not assessed** if no mapped question was shown and answered. Not assessed is never a pass, and Addressed means only that the questions on it raised nothing, not that the framework is met. The NIST AI 600-1, OWASP and Singapore tables appear only for generative systems.

Mapped NIST AI RMF 1.0 subcategories (42): GOVERN 1.1, GOVERN 1.5, GOVERN 1.6, GOVERN 2.1, GOVERN 2.2, GOVERN 2.3, GOVERN 3.2, GOVERN 4.2, GOVERN 5.1, GOVERN 6.1, MAP 1.1, MAP 2.1, MAP 2.2, MAP 2.3, MAP 3.2, MAP 3.3, MAP 3.4, MAP 3.5, MAP 4.1, MAP 4.2, MAP 5.1, MEASURE 1.3, MEASURE 2.4, MEASURE 2.5, MEASURE 2.6, MEASURE 2.7, MEASURE 2.8, MEASURE 2.9, MEASURE 2.10, MEASURE 2.11, MEASURE 2.12, MEASURE 3.1, MEASURE 3.3, MANAGE 1.1, MANAGE 1.3, MANAGE 1.4, MANAGE 2.3, MANAGE 2.4, MANAGE 3.2, MANAGE 4.1, MANAGE 4.2, MANAGE 4.3.

Mapped ISO/IEC 42001 clauses and controls (35): 4.1 Understanding the organization and its context; 5.3 Roles, responsibilities and authorities; 6.1.2 AI risk assessment; 6.1.3 AI risk treatment; 6.1.4 AI system impact assessment; 6.3 Planning of changes; 7.2 Competence; 7.3 Awareness; 7.4 Communication; 7.5 Documented information; 8.2 AI risk assessment; 8.3 AI risk treatment; 8.4 AI system impact assessment; 9.1 Monitoring, measurement, analysis and evaluation; A.3.2 AI roles and responsibilities; A.4.6 Human resources; A.5.2 AI system impact assessment process; A.5.4 Assessing AI system impact on individuals or groups of individuals; A.5.5 Assessing societal impacts of AI systems; A.6.2.4 AI system verification and validation; A.6.2.5 AI system deployment; A.6.2.6 AI system operation and monitoring; A.6.2.7 AI system technical documentation; A.6.2.8 AI system recording of event logs; A.7.2 Data for development and enhancement of AI system; A.7.3 Acquisition of data; A.7.4 Quality of data for AI systems; A.7.5 Data provenance; A.8.2 System documentation and information for users; A.8.4 Communication of incidents; A.8.5 Information for interested parties; A.9.2 Processes for responsible use of AI systems; A.9.4 Intended use of the AI system; A.10.2 Allocating responsibilities; A.10.3 Suppliers.

Singapore dimensions: 1 Accountability; 2 Data; 3 Trusted Development and Deployment; 4 Incident Reporting; 5 Testing and Assurance; 6 Security; 7 Content Provenance; 8 Safety and Alignment R&D; 9 AI for Public Good.

Reading a result: start with the gaps in the register, not the tables. Then look down the Not assessed rows: each is either a question that did not apply (fine) or one left unanswered (go back). A long run of Addressed rows on a system with a thin answer set is the pattern to distrust.

8. Worked examples

The eight scenarios used to test the pathway, run through the shipped code. Answers beyond the intake are realistic but invented.

Demand forecasting model (classic ML, internal)

Intake factor	Answer	Points
Effect of the output on people	No decisions about people	0 of 4
Reversibility of a wrong output	Not applicable: its output has no effect on people	0 of 4
Number of people affected each year	Fewer than 100	0 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	Low-impact actions only	1 of 3
When a human acts on an individual case	On flagged or contested cases only	1 of 3
Use area (Annex III)	Not an Annex III high-risk system	0 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Confidential business information	1 of 3

Triggers: generates No, foundation model No, free-form prompts No, EU nexus Yes.

- **Impact level:** Level I (3 of 29, 10 percent).
- **Questions shown:** 48. **Modules:** Core, Impact, AI Act, Governance.
- **EU AI Act:** Not high-risk.
- **Overall:** Low (worst finding). **Handovers:** none.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place

Register:

- Low, Core: Users not trained on the system's limits

Internal assistant over company documents (RAG)

Intake factor	Answer	Points
Effect of the output on people	No decisions about people	0 of 4
Reversibility of a wrong output	Easily, and quickly	0 of 4
Number of people affected each year	100 to 10,000	1 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	None - a human approves every action	0 of 3
When a human acts on an individual case	Before every decision takes effect	0 of 3
Use area (Annex III)	Not an Annex III high-risk system	0 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Personal data, Confidential business information	2 of 3

Triggers: generates Yes, foundation model Yes, free-form prompts Yes, EU nexus Yes.

- **Impact level:** Level I (3 of 29, 10 percent).
- **Questions shown:** 64. **Modules:** Core, Impact, GenAI, AI Act, Governance.

- **EU AI Act:** Not high-risk.
- **Overall:** Medium (worst finding). **Handovers:** Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place

Register:

- Medium, GenAI: Prompt injection not tested
- Low, GenAI: Outputs not checked for leakage
- Low, GenAI: Harmful content not filtered
- Low, GenAI: Model and components not documented
- Low, GenAI: Bias not evaluated
- Low, Core (also GenAI): Users not trained on limits

Customer service chatbot for the public, EU

Intake factor	Answer	Points
Effect of the output on people	Supports decisions with minor effects on people	1 of 4
Reversibility of a wrong output	With effort, or after some time	2 of 4
Number of people affected each year	More than 1 million	3 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	Low-impact actions only	1 of 3
When a human acts on an individual case	No human review	3 of 3
Use area (Annex III)	Not an Annex III high-risk system	0 of 4
Who uses it	The public	2 of 2
Sensitivity of the data	Personal data	2 of 3

Triggers: generates Yes, foundation model Yes, free-form prompts Yes, EU nexus Yes.

- **Impact level:** Level II (14 of 29, 48 percent).
- **Questions shown:** 68. **Modules:** Core, Impact, GenAI, AI Act, Governance.
- **EU AI Act:** Not high-risk.
- **Overall:** High (worst finding). **Handovers:** Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place
- Tell people they are interacting with an AI system, unless obvious (Provider; from 2 August 2026): Partly
- Mark synthetic audio, image, video or text in a machine-readable way (Provider; from 2 August 2026; generators on the market before then by 2 December 2026): Partly

Register:

- High, GenAI: Not red-teamed
- Medium, GenAI: Prompt injection not tested
- Medium, Core (also GenAI): Output relied on without review
- Low, GenAI: Inputs not screened

- Low, GenAI: Outputs not checked for leakage
- Low, GenAI: Harmful content not filtered
- Low, AI Act (also GenAI): AI use or synthetic content not disclosed
- Low, GenAI: Model and components not documented
- Low, GenAI: No ATLAS threat model
- Low, GenAI: Bias not evaluated
- Low, Core (also GenAI): Users not trained on limits
- Low, GenAI: Energy use unknown
- Low, AI Act: Transparency duties partly met

LLM screening of job applications

Intake factor	Answer	Points
Effect of the output on people	Supports decisions with legal or similarly significant effects on people	3 of 4
Reversibility of a wrong output	Not, or only with great difficulty	4 of 4
Number of people affected each year	10,000 to 1 million	2 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	Low-impact actions only	1 of 3
When a human acts on an individual case	Before every decision takes effect	0 of 3
Use area (Annex III)	4. Employment, workers' management and access to self-employment	3 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Personal data	2 of 3

Triggers: generates Yes, foundation model Yes, free-form prompts No, EU nexus Yes.

- **Impact level:** Level III (15 of 29, 52 percent).
- **Questions shown:** 82. **Modules:** Core, Impact, GenAI, AI Act, Governance.
- **EU AI Act:** High-risk (Annex III).
- **Overall:** High (worst finding). **Handovers:** Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place
- Use according to the instructions for use, with assigned human oversight (Deployer; from 2 December 2027 (Annex III)): In place
- Input data relevant and representative, where you control it (Deployer; from 2 December 2027 (Annex III)): Applies
- Monitor, report risks and serious incidents, suspend use; keep logs six months (Deployer; from 2 December 2027 (Annex III)): In place
- Inform workers' representatives before use at work, and inform people subject to decisions (Deployer; from 2 December 2027 (Annex III)): Partly
- Explain the role of the system in individual decisions on request (Deployer; from 2 December 2027 (Annex III)): Partly
- Know when you become the provider (name, substantial modification, change of purpose) (Deployer, importer, distributor; from 2 December 2027 (Annex III)): Applies

Register:

- High, Core: No check for unequal outcomes

- Medium, GenAI: Prompt injection not tested
- Low, GenAI: Inputs not screened
- Low, GenAI: Outputs not checked for leakage
- Low, GenAI: Harmful content not filtered
- Low, GenAI: Model and components not documented
- Low, GenAI: No ATLAS threat model
- Low, GenAI: Bias not evaluated
- Low, Core (also GenAI): Users not trained on limits
- Low, GenAI: Energy use unknown

Benefit eligibility scoring by a public body

Intake factor	Answer	Points
Effect of the output on people	Supports decisions with legal or similarly significant effects on people	3 of 4
Reversibility of a wrong output	With effort, or after some time	2 of 4
Number of people affected each year	More than 1 million	3 of 3
People in a vulnerable situation	People in financial hardship, Persons with disabilities	2 of 3
Actions taken without human approval	Low-impact actions only	1 of 3
When a human acts on an individual case	On flagged or contested cases only	1 of 3
Use area (Annex III)	5(a). Eligibility for public assistance benefits and services	3 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Personal data, Special category data	3 of 3

Triggers: generates No, foundation model No, free-form prompts No, EU nexus Yes.

- **Impact level:** Level III (18 of 29, 62 percent).
- **Questions shown:** 62. **Modules:** Core, Impact, AI Act, Governance.
- **EU AI Act:** High-risk (Annex III).
- **Overall:** Medium (worst finding). **Handovers:** FRIA (required), Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place
- Use according to the instructions for use, with assigned human oversight (Deployer; from 2 December 2027 (Annex III)): In place
- Input data relevant and representative, where you control it (Deployer; from 2 December 2027 (Annex III)): Applies
- Monitor, report risks and serious incidents, suspend use; keep logs six months (Deployer; from 2 December 2027 (Annex III)): In place
- Inform workers' representatives before use at work, and inform people subject to decisions (Deployer; from 2 December 2027 (Annex III)): In place
- Register the use in the EU database (Deployer (public authority); from 2 December 2027 (Annex III)): Applies
- Fundamental rights impact assessment before first use (Deployer; from 2 December 2027 (Annex III)): Not assessed
- Explain the role of the system in individual decisions on request (Deployer; from 2 December 2027 (Annex III)): Partly

- Know when you become the provider (name, substantial modification, change of purpose) (Deployer, importer, distributor; from 2 December 2027 (Annex III)): Applies

Register:

- Medium, Core: No human makes the final decision
- Low, Core: Users not trained on the system's limits

Provider of a general-purpose model offered by API

Intake factor	Answer	Points
Effect of the output on people	No decisions about people	0 of 4
Reversibility of a wrong output	Not applicable: its output has no effect on people	0 of 4
Number of people affected each year	More than 1 million	3 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	None - a human approves every action	0 of 3
When a human acts on an individual case	After the fact, by sampling	2 of 3
Use area (Annex III)	Not an Annex III high-risk system	0 of 4
Who uses it	The public	2 of 2
Sensitivity of the data	Personal data	2 of 3

Triggers: generates Yes, foundation model Yes, free-form prompts Yes, EU nexus Yes.

- **Impact level:** Level II (9 of 29, 31 percent).
- **Questions shown:** 77. **Modules:** Core, Impact, GenAI, AI Act, Governance.
- **EU AI Act:** Not high-risk.
- **Overall:** High (worst finding). **Handovers:** Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Screen the use against the prohibited practices (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): In place
- Tell people they are interacting with an AI system, unless obvious (Provider; from 2 August 2026): Partly
- Mark synthetic audio, image, video or text in a machine-readable way (Provider; from 2 August 2026; generators on the market before then by 2 December 2026): Partly
- Notify the Commission within two weeks of meeting the systemic risk threshold (GPAI model provider; from 2 August 2025): Applies
- Technical documentation (Annex XI) and information for downstream providers (Annex XII) (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): In place
- Copyright policy, including rights reservations (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): Partly
- Public summary of training content on the AI Office template (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): Gap
- Authorised representative in the Union (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): In place
- Model evaluation including adversarial testing; assess and mitigate systemic risks (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): In place
- Track and report serious incidents to the AI Office (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): Partly

- Cybersecurity for the model and its infrastructure (GPAI model provider; from 2 August 2025; models on the market before then by 2 August 2027): In place

Register:

- High, AI Act: Training content summary missing or partial
- Medium, GenAI: Prompt injection not tested
- Medium, Core (also GenAI): Output relied on without review
- Medium, GenAI: Training data not vetted
- Medium, AI Act: Copyright policy missing or partial
- Medium, AI Act: Serious incident reporting missing or partial
- Low, GenAI: Inputs not screened
- Low, GenAI: Outputs not checked for leakage
- Low, GenAI: Harmful content not filtered
- Low, AI Act (also GenAI): AI use or synthetic content not disclosed
- Low, GenAI: Model and components not documented
- Low, GenAI: No ATLAS threat model
- Low, GenAI: Bias not evaluated
- Low, Core (also GenAI): Users not trained on limits
- Low, GenAI: Energy use unknown
- Low, AI Act: Transparency duties partly met

Emotion recognition of staff in the workplace

Intake factor	Answer	Points
Effect of the output on people	Supports decisions with legal or similarly significant effects on people	3 of 4
Reversibility of a wrong output	With effort, or after some time	2 of 4
Number of people affected each year	100 to 10,000	1 of 3
People in a vulnerable situation	People in a dependent position (employees, detainees, asylum seekers)	2 of 3
Actions taken without human approval	Low-impact actions only	1 of 3
When a human acts on an individual case	After the fact, by sampling	2 of 3
Use area (Annex III)	1. Biometrics (remote identification, categorisation, emotion recognition)	4 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Personal data, Special category data	3 of 3

Triggers: generates No, foundation model No, free-form prompts No, EU nexus Yes.

- **Impact level:** Level III (18 of 29, 62 percent).
- **Questions shown:** 57. **Modules:** Core, Impact, AI Act, Governance.
- **EU AI Act:** Prohibited.
- **Overall:** Prohibited practice (worst finding). **Handovers:** Full DPIA.

Obligations listed:

- AI literacy: support it among staff and others who operate the system on your behalf (Provider and deployer; from 2 February 2025): Partly
- Prohibited practice: do not place on the market, put into service or use (Everyone; from 2 February 2025 (points (ba) and (bb) from 2 December 2026)): Gap

Register:

- High, AI Act: Prohibited practice

- Medium, Core: No human makes the final decision
- Low, Core: Users not trained on the system's limits

Coding assistant used only outside the EU

Intake factor	Answer	Points
Effect of the output on people	No decisions about people	0 of 4
Reversibility of a wrong output	Not applicable: its output has no effect on people	0 of 4
Number of people affected each year	100 to 10,000	1 of 3
People in a vulnerable situation	none	0 of 3
Actions taken without human approval	None - a human approves every action	0 of 3
When a human acts on an individual case	Before every decision takes effect	0 of 3
Use area (Annex III)	Not an Annex III high-risk system	0 of 4
Who uses it	Staff only	0 of 2
Sensitivity of the data	Source code or credentials	1 of 3

Triggers: generates Yes, foundation model Yes, free-form prompts Yes, EU nexus No.

- **Impact level:** Level I (2 of 29, 7 percent).
- **Questions shown:** 56. **Modules:** Core, Impact, GenAI, Governance.
- **EU AI Act:** Not in scope (no EU nexus).
- **Overall:** Medium (worst finding). **Handovers:** none.

Register:

- Medium, GenAI: Prompt injection not tested
- Low, GenAI: Harmful content not filtered
- Low, GenAI: Model and components not documented
- Low, GenAI: Bias not evaluated
- Low, Core (also GenAI): Users not trained on limits

9. Every question in the pathway

By step, as shipped. Ids are shown because reused questions keep the id of the tool they come from, which is how answers carry into the FRIA. Mappings: N = NIST AI RMF subcategories, I = ISO/IEC 42001, S = Singapore dimensions, G = NIST AI 600-1 risks, O = OWASP items (the last two from the Generative AI checks).

Step 1 of 18. The system and its use

Intake. Always shown.

- **AI system or use case name** `name` (short text)
- **What it does: its purpose, the decision or task it supports, who uses it and where** `description` (long text)
 - Maps to: N MAP 1.1, MAP 2.1; I A.9.4
- **Lifecycle stage** `lifecycle` (choose one)
 - Options: Idea / concept; Pilot; Production; Retired
 - Follow-up: Date placed on the market or put into service (or planned), any significant change since, and whether real-world testing is involved: these set which AI Act dates and transition rules apply
 - Maps to: N GOVERN 1.6; I A.6.2.5
- **Vendor and model: who provides the system or the model it runs on, and which version or release is assessed** `provider` (short text)
 - Maps to: N GOVERN 6.1, MAP 4.1; I A.10.3; S Accountability
- **Date of first use (planned or actual)** `firstUseDate` (date)
- **Use area: does the intended purpose fall in one of the high-risk areas of Annex III of the EU AI Act? Answer this even outside the EU; the area also sets the sector factor of the impact level.** `annexIIIArea` (choose one)
 - Options: 1. Biometrics (remote identification, categorisation, emotion recognition); 2. Critical infrastructure (safety components); 3. Education and vocational training; 4. Employment, workers' management and access to self-employment; 5(a). Eligibility for public assistance benefits and services; 5(b). Creditworthiness or credit scoring of natural persons (not fraud detection); 5(c). Risk assessment and pricing in life and health insurance; 5(d). Emergency call evaluation, dispatch and patient triage; 6. Law enforcement; 7. Migration, asylum and border control; 8. Administration of justice and democratic processes; Not an Annex III high-risk system; Not sure
 - Maps to: N GOVERN 1.1, MAP 1.1, MAP 3.3; I 4.1

Step 2 of 18. People and data

Intake. Always shown.

- **Who is affected by the system's output?** `affectedCategories` (choose any)
 - Options: Job applicants or employees; Students or learners; Applicants for or recipients of public benefits; Consumers or customers; Patients or people seeking emergency help; Suspects, defendants or people in contact with law enforcement; Migrants, asylum seekers or travellers; Members of the public in a public space; Other
 - Follow-up: Specify
 - Maps to: N MAP 1.1, MAP 5.1; I A.5.4
- **Are any of them in a vulnerable situation? Leave blank if none.** `friaVulnerable` (choose any)
 - Options: Children; Elderly people; Persons with disabilities; People in financial hardship; People in a dependent position (employees, detainees, asylum seekers); Minority or under-represented groups; Other
 - Follow-up: Specify
 - Maps to: N MAP 5.1; I A.5.4
- **Roughly how many people are affected each year?** `affectedScale` (choose one)
 - Options: Fewer than 100; 100 to 10,000; 10,000 to 1 million; More than 1 million

- Maps to: N MAP 5.1; I 6.1.4
- **Does the output make or support decisions about people?** `aipDecisionEffect` (choose one)
 - Options: No decisions about people; Supports decisions with minor effects on people; Supports decisions with legal or similarly significant effects on people; Makes decisions with legal or similarly significant effects on its own; Not sure
 - Maps to: N MAP 3.3, MAP 5.1; I 6.1.4
- **If an output is wrong, can its effect on a person be reversed?** `aipReversibility` (choose one)
 - Options: Easily, and quickly; With effort, or after some time; Not, or only with great difficulty; Not applicable: its output has no effect on people; Not sure
 - Maps to: N MAP 5.1; I 6.1.4
- **Who uses it?** `gaiUsers` (choose one)
 - Options: Staff only; Selected business partners; The public
 - Maps to: N MAP 1.1; I A.9.4
- **What data does the system take in, retrieve or produce?** `gaiPromptData` (choose any)
 - Options: Personal data; Special category data; Confidential business information; Source code or credentials; None of these
 - Maps to: N MEASURE 2.10; I A.7.2; S Data

Step 3 of 18. Autonomy and human review

Intake. Always shown.

- **What actions can the system take without human approval?** `autonomyLevel` (choose one)
 - Options: None - a human approves every action; Low-impact actions only; Broad autonomous action
 - Follow-up: Briefly describe what it can do without approval
 - Maps to: N GOVERN 3.2, MAP 3.5; I A.9.2
- **When does a human act on an individual case or output before it takes effect?** `oversightMode` (choose one)
 - Options: Before every decision takes effect; On flagged or contested cases only; After the fact, by sampling; No human review
 - Maps to: N GOVERN 3.2, MAP 3.5; I A.9.2; S Accountability

Step 4 of 18. What applies

Triggers. Always shown.

- **Does it generate text, images, audio, video or code?** `aipGenerates` (yes / no)
 - Maps to: N MAP 2.1
- **Is it built on, or does it call, a foundation or general-purpose model?** `aipFoundationModel` (yes / no)
 - Maps to: N MAP 2.1, MAP 4.1
- **Can users give it free-form prompts?** `aipFreePrompts` (yes / no)
 - Maps to: N MAP 2.1
- **Is it placed on the EU market or put into service in the EU, used in the EU, or is its output used in the EU (EU AI Act Article 2(1))?** `aipEu` (choose one)
 - Options: Yes; No; Not sure
 - Maps to: N GOVERN 1.1; I 4.1

Step 5 of 18. Core: oversight, fairness and logging

Core. Always shown.

- **Are named people or roles assigned to oversee the system and its output?** `oversightAssigned` (yes / no)
 - Follow-up: Which roles?

- Maps to: N GOVERN 2.1, GOVERN 3.2, MAP 3.5; I A.3.2, A.9.2; S Accountability
- **Do they have the competence, training and authority to disregard or override the output?** `oversightCompetence` (choose one)
 - Options: Yes; Partially; No
 - Shown when: oversight is assigned
 - Maps to: N GOVERN 2.2, MAP 3.4; I 7.2; S Accountability
- **Are reviewers protected against automation bias (output shown with its confidence and limitations, a reason required to follow it in sensitive cases, workload that allows real review)?** `automationBias` (choose one)
 - Options: Yes; Partially; No
 - Shown when: the output supports or makes decisions about people, at impact level III or IV
 - Maps to: N MAP 3.5, MEASURE 2.9; I A.9.2
- **Are the people who use or oversee the system trained on its limits, so they do not over-rely on it? (This is also the AI literacy measure of EU AI Act Article 4.)** `gaiUserGuidance` (choose one)
 - Options: Yes; Partially; No
 - Maps to: N GOVERN 2.2, MAP 3.4; I 7.2, 7.3, A.4.6; G Human-AI configuration, Confabulation; O LLM09
- **Has the output been checked for different error rates or outcomes across groups of the people it affects?** `biasEvaluated` (choose one)
 - Options: Yes; Planned; No; Not possible with the data available
 - Follow-up: What was found, or why it cannot be done?
 - Shown when: the output supports or makes decisions about people
 - Maps to: N MEASURE 2.11; I A.5.4, A.7.4; S Testing and Assurance
- **Are the system's actions and data access logged, auditable and attributable to a responsible owner?** `loggingInPlace` (yes / no)
 - Follow-up: What's missing, and what's the plan to close the gap?
 - Maps to: N MEASURE 2.4, MANAGE 4.1; I A.6.2.8; S Accountability

Step 6 of 18. Core: data, access and third parties

Core. Always shown.

- **Is training or input data sourced from third parties or public/external platforms?** `thirdPartyData` (yes / no)
 - Follow-up: Which third parties/platforms, under what licence or lawful access, and with what provenance record? Personal data in that material needs its own GDPR basis.
 - Maps to: N GOVERN 6.1, MAP 4.1; I A.7.3, A.7.5; S Data
- **Can the provider of the system or model retain your inputs or use them for training?** `gaiProviderUse` (choose one)
 - Options: No, contractually excluded; Retained for abuse monitoring only; Yes; Not sure; Not applicable (self-hosted)
 - Maps to: N GOVERN 6.1, MEASURE 2.10; I A.10.3; S Data; G Data privacy, Value chain and component integration; O LLM02
- **Does it have access to sensitive or business-critical systems/data beyond what's strictly needed for its task?** `broadDataAccess` (yes / no)
 - Follow-up: Which systems/data, and why is that scope needed?
 - Maps to: N MEASURE 2.7; S Security
- **Does the system coordinate with other AI agents, models, or external services (multi-agent orchestration)?** `multiAgent` (yes / no)
 - Maps to: N MAP 4.1; I A.10.3

- **Are all connected agents/systems identified and documented?** `multiAgentDocumented` (yes / no)
 - Follow-up: a follow-up note, worded according to the answer
 - Shown when: the system coordinates with other agents or services
 - Maps to: N GOVERN 1.6, MAP 4.1; I A.10.3; S Accountability
- **Does the system process business-critical data (contracts, transactions, financial, legal, or audit records)?** `businessCriticalData` (yes / no)
 - Follow-up: Which records?
 - Shown when: impact level III or IV
 - Maps to: N MAP 4.2; S Security
- **Could its output or data be exposed to competitors or unauthorized external parties?** `competitorExposure` (yes / no)
 - Follow-up: Describe how exposure could occur and any controls in place
 - Shown when: impact level III or IV
 - Maps to: N MEASURE 2.7; S Security

Step 7 of 18. Impact on people

Impact. Always shown.

- **Describe the specific harms: what could go wrong, for whom, and how it would show up (a wrong answer relied on, a biased score, an intrusive inference, an unsafe action)** `harmsDescription` (long text)
 - Maps to: N MAP 3.2, MAP 5.1; I 6.1.4, 8.4, A.5.4
- **Which fundamental rights could the system interfere with?** `rightsAtRisk` (choose any)
 - Options: Human dignity (Art. 1); Respect for private and family life (Art. 7); Protection of personal data (Art. 8); Freedom of expression and information (Art. 11); Freedom of assembly and association (Art. 12); Right to education (Art. 14); Freedom to choose an occupation and right to work (Art. 15); Right to asylum and protection on removal (Arts. 18 and 19); Non-discrimination (Art. 21); Equality between women and men (Art. 23); Rights of the child (Art. 24); Rights of the elderly (Art. 25); Integration of persons with disabilities (Art. 26); Fair and just working conditions (Art. 31); Social security and social assistance (Art. 34); Health care (Art. 35); Consumer protection (Art. 38); Right to good administration (Art. 41); Right to an effective remedy and to a fair trial (Art. 47); Presumption of innocence and right of defence (Art. 48)
 - Shown when: impact level III or IV
 - Maps to: N MAP 5.1; I A.5.4
- **Effects beyond individuals: on groups, communities, society or the environment** `aipSocietalImpact` (long text)
 - Shown when: impact level III or IV
 - Maps to: N MAP 5.1; I A.5.5; S AI for Public Good
- **Have the provider's instructions, documentation or model card been reviewed, including known limitations, accuracy levels and foreseeable misuse?** `providerInfoReviewed` (choose one)
 - Options: Yes; Partially; No
 - Shown when: impact level III or IV
 - Maps to: N GOVERN 6.1, MAP 2.2; I A.8.2
- **Inherent severity: how serious would the worst credible harm be, before any measures?** `friaInherentSeverity` (choose one)
 - Options: Negligible - a minor, short-lived effect on the right that people overcome without difficulty; Limited - a real interference people can overcome with some difficulty; Significant - a serious interference that is hard to reverse or affects many people; Maximum - an irreversible interference, or one that denies access to an essential service, liberty or livelihood
 - Maps to: N MAP 5.1; I 8.4, A.5.2

- **Inherent likelihood: how likely is it, before any measures?** `friaInherentLikelihood` (choose one)
 - Options: Negligible - it does not seem possible in this deployment; Limited - it seems unlikely in this deployment; Significant - it seems possible in this deployment; Maximum - it is expected to happen in this deployment
 - Maps to: N MAP 5.1; I 8.4, A.5.2
- **Which measures reduce the risks identified (thresholds, exclusions, second review, data quality checks, limits on scope)?** `mitigationMeasures` (long text)
 - Maps to: N MANAGE 1.3; I 6.1.3, 8.3
- **What happens if a risk materialises: who is told, how affected people are contacted, and how decisions are corrected?** `materialiseMeasures` (long text)
 - Shown when: impact level III or IV
 - Maps to: N MANAGE 2.3, MANAGE 4.3; I A.8.4; S Incident Reporting
- **Can affected people complain or contest an outcome?** `complaintMechanism` (choose one)
 - Options: Yes; Planned; No
 - Shown when: impact level III or IV, and the output supports or makes decisions about people
 - Maps to: N GOVERN 5.1, MEASURE 3.3; I A.8.5; S Accountability
- **Can you give an affected person a clear explanation of the role the system played in a decision about them?** `explanationProcess` (choose one)
 - Options: Yes; Planned; No
 - Shown when: impact level III or IV, and the output supports or makes decisions about people
 - Maps to: N MEASURE 2.8, MEASURE 2.9; I A.8.5
- **Residual severity, with every measure above in place** `friaResidualSeverity` (choose one)
 - Options: Negligible - a minor, short-lived effect on the right that people overcome without difficulty; Limited - a real interference people can overcome with some difficulty; Significant - a serious interference that is hard to reverse or affects many people; Maximum - an irreversible interference, or one that denies access to an essential service, liberty or livelihood
 - Maps to: N MANAGE 1.4; I 8.3
- **Residual likelihood, with every measure above in place** `friaResidualLikelihood` (choose one)
 - Options: Negligible - it does not seem possible in this deployment; Limited - it seems unlikely in this deployment; Significant - it seems possible in this deployment; Maximum - it is expected to happen in this deployment
 - Maps to: N MANAGE 1.4; I 8.3

Step 8 of 18. Generative AI: patterns and model

Generative AI module. Shown when a generative AI trigger is Yes (generates content, foundation model, or free-form prompts).

- **Which patterns describe it?** `gaiPatterns` (choose any)
 - Options: Internal assistant or chat; Customer-facing chat or assistant; Search or question answering over our own documents (RAG); Agent that calls tools or other systems; Content generation (text, images, audio, video); Code generation
 - Maps to: N MAP 2.1
- **Where does the model come from?** `gaiModelSource` (choose one)
 - Options: Third-party model through an API; Open-weight model we host; Third-party or open model we fine-tuned; Model we trained ourselves
 - Maps to: N MAP 4.1; I A.10.3; S Accountability

Step 9 of 18. Generative AI: inputs and prompts

Generative AI module. Shown when a generative AI trigger is Yes.

- **Does the system read content it does not control (web pages, emails, uploaded files, third-party documents)?** `gaiUntrustedContent` (yes / no)
 - Maps to: N MAP 4.1; S Security
- **Has it been tested against direct and indirect prompt injection?** `gaiInjectionTested` (choose one)
 - Options: Yes, before release and on every major change; Once; No
 - Maps to: N MEASURE 2.7; I A.6.2.4; S Testing and Assurance, Security; G Information security; O LLM01
- **Does the system prompt or configuration hold secrets, credentials, or access rules the model is trusted to enforce?** `gaiSystemPromptSecrets` (choose one)
 - Options: No; Yes; Not sure
 - Maps to: N MEASURE 2.7; S Security; G Information security; O LLM07
- **Are inputs screened before they reach the model (length limits, known attack patterns, content classification)?** `gaiInputFiltering` (choose one)
 - Options: Yes; Partially; No
 - Shown when: impact level III or IV, or the system is public-facing
 - Maps to: N MANAGE 1.3, MEASURE 2.7; S Security; G Information security, Dangerous, violent or hateful content; O LLM01

Step 10 of 18. Generative AI: data, privacy and intellectual property

Generative AI module. Shown when a generative AI trigger is Yes.

- **Are outputs checked for personal or confidential data before they are shown or stored?** `gaiOutputLeakCheck` (choose one)
 - Options: Yes; Partially; No
 - Maps to: N MEASURE 2.10; S Data; G Data privacy; O LLM02
- **Does retrieval respect each user's own access rights, so the assistant cannot surface a document the user could not open?** `gaiRagPermissions` (choose one)
 - Options: Yes; Partially; No
 - Shown when: the patterns include search or question answering over own documents (RAG)
 - Maps to: N MEASURE 2.7, MEASURE 2.10; S Data, Security; G Data privacy, Information security; O LLM08, LLM02
- **Is the vector store protected like the source data (access control, encryption, deletion when the source is deleted)?** `gaiEmbeddingStore` (choose one)
 - Options: Yes; Partially; No
 - Shown when: RAG, and impact level III or IV or a public-facing system
 - Maps to: N MEASURE 2.7; S Security; G Data privacy, Information security; O LLM08
- **Are outputs used externally checked for third-party copyrighted material, and are the licence terms of the model and its training data understood?** `gaiIpCheck` (choose one)
 - Options: Yes; Partially; No; Outputs are not used externally
 - Maps to: N GOVERN 6.1, MAP 4.1; S Data; G Intellectual property

Step 11 of 18. Generative AI: outputs and accuracy

Generative AI module. Shown when a generative AI trigger is Yes.

- **Is model output passed to another system (rendered as HTML, run as code or SQL, used in an API call) without validation?** `gaiOutputHandling` (choose one)
 - Options: No, it is validated or only shown as text; Yes; Not sure
 - Maps to: N MEASURE 2.7; I A.6.2.4; S Security; G Information security; O LLM05

- **Are answers grounded in sources and shown with citations or a confidence signal?**

`gaiGrounding` (choose one)

- Options: Yes; Partially; No; Not applicable
- Maps to: N MEASURE 2.5, MEASURE 2.9; S Trusted Development and Deployment; G Confabulation, Information integrity; O LLM09

- **Are there filters for violent, hateful, abusive, sexual and dangerous (including CBRN) content, in both prompts and outputs?** `gaiContentFilters` (choose one)

- Options: Yes, tested; Yes, provider defaults only; No
- Maps to: N MANAGE 1.3, MEASURE 2.6; S Trusted Development and Deployment; G CBRN information or capabilities, Dangerous, violent or hateful content, Obscene, degrading and/or abusive content

- **Are people told when they interact with AI, and is synthetic content marked as such?**

`gaiDisclosure` (choose one)

- Options: Yes; Partially; No; Not applicable
- Shown when: the AI Act module is closed (EU trigger No); otherwise Article 50 asks it
- Maps to: N MEASURE 2.8; I A.8.2; S Content Provenance; G Information integrity

Step 12 of 18. Generative AI: agency, supply chain and consumption

Generative AI module. Shown when a generative AI trigger is Yes.

- **What can the system do through its tools?** `gaiToolPermissions` (choose one)

- Options: Nothing beyond producing text; Read-only access; Limited write actions; Broad write or transactional actions
- Shown when: the patterns include an agent that calls tools
- Maps to: N GOVERN 3.2, MAP 3.5; I A.9.2; S Trusted Development and Deployment; G Human-AI configuration; O LLM06

- **Do high-impact actions need human approval?** `gaiApproval` (choose one)

- Options: Yes; Some; No
- Shown when: an agent with limited or broad write actions
- Maps to: N MAP 3.5; I A.9.2; S Accountability; G Human-AI configuration; O LLM06

- **Are the model, its version and its third-party components documented (model card, licence, an AI bill of materials)?** `gaiProvenance` (choose one)

- Options: Yes; Partially; No
- Maps to: N MANAGE 3.2, MAP 4.1; I A.6.2.7, A.10.3; S Trusted Development and Deployment; G Value chain and component integration; O LLM03

- **Is fine-tuning or training data vetted for poisoning, provenance and quality?**

`gaiTrainingDataVetted` (choose one)

- Options: Yes; Partially; No
- Shown when: the model is fine-tuned or trained in-house
- Maps to: N MAP 2.3, MEASURE 2.7; I A.7.4, A.7.5; S Data; G Information security, Value chain and component integration; O LLM04

- **Are there rate limits, token budgets and cost alerts?** `gaiRateLimits` (choose one)

- Options: Yes; Partially; No
- Shown when: impact level III or IV, or the system is public-facing
- Maps to: N MEASURE 2.7; S Security; G Environmental impacts; O LLM10

Step 13 of 18. Generative AI: testing, monitoring and people

Generative AI module. Shown when a generative AI trigger is Yes.

- **Has the system been red-teamed or adversarially tested?** `gaiRedTeam` (choose one)

- Options: Yes, including by people outside the build team; Yes, internally; No
- Maps to: N MEASURE 1.3, MEASURE 2.7; I A.6.2.4; S Testing and Assurance; G CBRN information or capabilities, Dangerous, violent or hateful content, Information security; O LLM01

- **Has a threat model been built against the MITRE ATLAS tactics and techniques?**

`gaiThreatModel` (choose one)

- Options: Yes; Partially; No
- Shown when: impact level III or IV, or the system is public-facing
- Maps to: N MAP 4.2, MEASURE 2.7; S Security; G Information security

- **Have outputs been evaluated for harmful bias or stereotyping across groups?** `gaiBiasEval` (choose one)

- Options: Yes; Partially; No
- Maps to: N MEASURE 2.11; S Testing and Assurance; G Harmful bias and homogenization

- **Are prompts and outputs logged and monitored, with a route for reporting and handling AI incidents?** `gaiMonitoring` (choose one)

- Options: Yes; Partially; No
- Maps to: N MANAGE 4.1, MANAGE 4.3, MEASURE 2.4; I A.6.2.6, A.8.4; S Incident Reporting; G Information integrity, Information security

- **Is the energy use or carbon footprint of the system known?** `gaiEnergy` (choose one)

- Options: Yes; Estimated; No
- Shown when: impact level III or IV, or the system is public-facing
- Maps to: N MEASURE 2.12; S AI for Public Good; G Environmental impacts

Step 14 of 18. EU AI Act: role and prohibited practices

EU AI Act module. Shown when the EU trigger is Yes or Not sure.

- **What is your role for this system?** `aiaRole` (choose any)

- Options: Provider of the AI system; Deployer; Importer; Distributor; Product manufacturer (the AI system is placed on the market with our product, under our name); Provider of a general-purpose AI model
- Maps to: N GOVERN 2.1, GOVERN 6.1; I A.10.2; S Accountability

- **What kind of deployer are you?** `deployerType` (choose one)

- Options: Body governed by public law; Private entity providing public services; Other private entity
- Shown when: the role includes deployer
- Maps to: N GOVERN 1.1

- **Is the use within the intended purpose stated in the provider's instructions for use?**

`intendedPurposeAligned` (choose one)

- Options: Yes; Partially; No; Not sure
- Follow-up: Where does the use go beyond the stated purpose?
- Shown when: the role includes deployer
- Maps to: N MAP 1.1, MAP 3.3; I A.9.4

- **Does the system fall into a prohibited-use category under the EU AI Act (e.g. social scoring, manipulative/subliminal techniques causing harm, exploiting vulnerabilities, untargeted facial-recognition scraping, workplace/education emotion inference, biometric categorization inferring protected attributes, or, from 2 December 2026, generating non-consensual intimate imagery or child sexual abuse material)?**

`prohibitedUse` (choose one)

- Options: No; Yes; Unsure
- Follow-up: Briefly explain why / what triggered this concern
- Maps to: N GOVERN 1.1, MANAGE 1.1; I 4.1, A.9.4

Step 15 of 18. EU AI Act: high-risk classification

EU AI Act module. Shown when the EU trigger is Yes or Not sure, and the use is not a prohibited practice.

- **Is it a product, or a safety component of a product, covered by EU product-safety law listed in Annex I (machinery, toys, medical devices, vehicles, aviation, marine**

equipment, rail, lifts, radio equipment, pressure equipment, PPE, gas appliances, cableways) that has to go through a third-party conformity assessment under that law?

highRiskAnnexI (choose one)

- Options: No; Yes; Unsure
- Follow-up: Which product legislation, and does it require third-party conformity assessment?
- Maps to: N GOVERN 1.1, MAP 3.3; I 4.1

• **Does one of the Article 6(3) conditions apply, so that the system does not pose a significant risk of harm?** aiaArt63 (choose one)

- Options: No, none of them applies; It performs a narrow procedural task; It improves the result of a previously completed human activity; It detects decision-making patterns or deviations from earlier patterns, and does not replace or influence the earlier human assessment without proper human review; It performs a preparatory task to an assessment relevant to an Annex III use; Not sure
- Shown when: the use area is an Annex III area
- Maps to: N GOVERN 1.1, MAP 3.3; I 4.1

• **Does the system profile natural persons?** aiaProfiling (yes / no)

- Shown when: an Annex III area and an Article 6(3) condition is claimed
- Maps to: N GOVERN 1.1, MAP 3.3; I 4.1

• **Is the Article 6(3) assessment documented before the system is placed on the market, and the system registered under Article 49(2)?** aiaArt63Documented (yes / no)

- Shown when: the Article 6(3) exemption holds and the role includes provider or product manufacturer
- Maps to: N GOVERN 1.1, GOVERN 1.6; I 7.5; S Accountability

• **Are affected people told that a high-risk AI system is used in decisions about them (Article 26(11))?** affectedAware (choose one)

- Options: Yes; Planned; No
- Shown when: deployer of an Annex III high-risk system whose output supports or makes decisions about people
- Maps to: N GOVERN 5.1, MEASURE 2.8; I A.8.5; S Accountability

Step 16 of 18. EU AI Act: general-purpose AI model

EU AI Act module. Shown when the EU trigger is Yes or Not sure, not prohibited, and the role includes provider of a general-purpose AI model.

• **Does the model have systemic risk?** aiaGpaiSystemic (choose one)

- Options: No; Yes: cumulative training compute above 10^{25} FLOP (presumed); Yes: designated by the Commission; Not sure
- Maps to: N GOVERN 1.1

• **Is it released under a free and open-source licence, with its weights, architecture and usage information public (Article 53(2))?** aiaGpaiOpenSource (yes / no)

- Maps to: N GOVERN 1.1

• **Is the model provider established outside the EU?** aiaGpaiOutsideEu (yes / no)

- Maps to: N GOVERN 1.1; S Accountability

• **Is the Annex XI technical documentation kept, and the Annex XII information available to downstream providers (Article 53(1)(a) and (b))?** aiaGpaiDocs (choose one)

- Options: Yes; Partially; No
- Shown when: the model is not open-source, or it has systemic risk
- Maps to: N MAP 2.2; I A.6.2.7, A.8.2; S Trusted Development and Deployment

• **Is there a policy to comply with EU copyright law, including rights reservations under Article 4(3) of Directive (EU) 2019/790 (Article 53(1)(c))?** aiaGpaiCopyright (choose one)

- Options: Yes; Partially; No
- Maps to: N GOVERN 6.1; I A.7.5; S Data

- **Is a sufficiently detailed summary of the training content published, on the AI Office template (Article 53(1)(d))?** `aiaGpaiSummary` (choose one)
 - Options: Yes; Partially; No
 - Maps to: N MAP 2.2; I A.7.5; S Data, Trusted Development and Deployment
- **Is an authorised representative established in the Union appointed by written mandate (Article 54)?** `aiaGpaiRep` (yes / no)
 - Shown when: the provider is outside the EU, and the model is not open-source or has systemic risk
 - Maps to: N GOVERN 1.1; S Accountability
- **Systemic risk: is the model evaluated with standardised protocols, including adversarial testing, and are systemic risks assessed and mitigated (Article 55(1)(a) and (b))?** `aiaGpaiEval` (choose one)
 - Options: Yes; Partially; No
 - Shown when: the model has systemic risk (presumed, designated or not sure)
 - Maps to: N MEASURE 1.3, MEASURE 2.6; I A.6.2.4; S Testing and Assurance, Safety and Alignment R&D
- **Systemic risk: are serious incidents tracked, documented and reported to the AI Office without undue delay (Article 55(1)(c))?** `aiaGpaiIncidents` (choose one)
 - Options: Yes; Partially; No
 - Shown when: the model has systemic risk (presumed, designated or not sure)
 - Maps to: N MANAGE 4.3; I A.8.4; S Incident Reporting
- **Systemic risk: is the model and its physical infrastructure adequately protected (Article 55(1)(d))?** `aiaGpaiCyber` (choose one)
 - Options: Yes; Partially; No
 - Shown when: the model has systemic risk (presumed, designated or not sure)
 - Maps to: N MEASURE 2.7; S Security

Step 17 of 18. EU AI Act: transparency (Article 50)

EU AI Act module. Shown when the EU trigger is Yes or Not sure, and the use is not a prohibited practice.

- **Is it intended to interact directly with people (a chatbot, a voice assistant, an agent that writes to people)?** `aiaInteracts` (yes / no)
 - Shown when: the generative AI patterns do not already say chat or assistant
 - Maps to: N GOVERN 1.1, MEASURE 2.8; I A.8.2
- **Does it recognise emotions or sort people into categories from biometric data?** `aiaEmotion` (yes / no)
 - Maps to: N GOVERN 1.1, MEASURE 2.8; I 7.4, A.8.5
- **Is it used to produce deep fakes (image, audio or video resembling real people, objects, places or events), or text published to inform the public on matters of public interest?** `aiaDeepfake` (choose one)
 - Options: No; Deep fakes; Text published to inform the public on matters of public interest; Both
 - Shown when: the system generates content
 - Maps to: N GOVERN 1.1, MEASURE 2.8; I 7.4, A.8.5; S Content Provenance
- **Are the transparency measures that apply in place: disclosure at the first interaction, machine-readable marking, information to people exposed, deep fake disclosure?** `aiaTransparencyDone` (choose one)
 - Options: Yes; Partially; No
 - Shown when: at least one Article 50 duty is in play (interaction, synthetic content, emotion recognition or biometric categorisation, deep fakes or public-interest text)
 - Maps to: N MEASURE 2.8; I A.8.2, A.8.5; S Content Provenance

Step 18 of 18. Governance and decision

Governance. Always shown.

- **System owner (name or role)** `aipSystemOwner` (short text)
 - Maps to: N GOVERN 2.1; I 5.3, A.3.2; S Accountability
- **Assessor (name or role)** `aipAssessor` (short text)
 - Maps to: N GOVERN 2.1, MEASURE 1.3; I 6.1.2, 8.2, A.3.2
- **Approver (name or role)** `aipApprover` (short text)
 - Maps to: N GOVERN 2.3; I 5.3; S Accountability
- **Decision** `aipDecision` (choose one)
 - Options: Approve; Approve with conditions; Reject; Not yet decided
 - Maps to: N MANAGE 1.1; I 6.1.3, 8.3
- **Conditions of the approval, each with an owner and a date** `aipConditions` (long text)
 - Shown when: the decision is approve with conditions
 - Maps to: N MANAGE 1.3; I 8.3
- **Evidence references: test reports, model cards, contracts, earlier assessments** `aipEvidence` (long text)
 - Shown when: impact level III or IV
 - Maps to: N GOVERN 4.2; I 7.5
- **Has this use case been reviewed by legal/compliance for regulatory risk?** `legalReview` (yes / no)
 - Follow-up: When is legal/compliance review planned?
 - Maps to: N GOVERN 1.1; I 4.1
- **Is there a process to suspend use, and to report to the provider and any authority, where the system presents a risk or a serious incident occurs?** `suspensionProcess` (choose one)
 - Options: Yes; Partially; No
 - Shown when: impact level III or IV
 - Maps to: N MANAGE 2.4, MANAGE 4.3; I A.8.4; S Incident Reporting
- **Next review date** `aipReviewDate` (date)
 - Maps to: N GOVERN 1.5, MEASURE 3.1; I 8.2, 9.1
- **Events that trigger a reassessment before that date** `aipReassessTriggers` (choose any)
 - Options: A new model, or a new version of the model; A new purpose, or new groups of users or affected people; A new data source, or a change to the training data; Use in a new country or jurisdiction; An incident, a complaint or a near miss; Performance or accuracy drifting from what was measured; A change in the law or in regulatory guidance
 - Maps to: N GOVERN 1.5, MANAGE 4.2; I 6.3, 8.2

10. Practice questions

1. What are the four triggers the pathway asks, and which two does it read from the intake instead?
2. Why does the pathway ask the FRIA's own questions in its intake and Impact step?
3. A system scores 52 percent. Which impact level, and what would 50 percent give?
4. Name the two floors and say what each protects against.
5. Why is there no mitigation deduction, unlike the Canadian method?
6. A public customer chatbot is at level II. Does it see the rate limits question?
7. When does the GenAI module ask about disclosure, and when does it not?
8. An Annex III system performs a narrow procedural task but profiles people. Is it high-risk?
9. A model provider releases an open-source model without systemic risk. Which duties remain?
10. From when do the Article 50 duties apply, and what is the extension in Article 111(4)?
11. Two findings rest on the same question: Core at medium, GenAI at low. What does the register show?
12. The Singapore table shows Safety and Alignment R&D as Not assessed. Is that a gap?
13. Why does the DPIA handover leave severity and likelihood unrated?
14. What is the difference between the impact level and the overall level?
15. Which benchmarks are law, and which are cited by number and title only?

Answers

1. Asked: generates content, foundation model, free-form prompts, EU nexus. Read from the intake: personal data (from the data question) and output that reaches people without review (from the review question).
2. So the answers carry into a FRIA started from the result under the same ids. The FRIA then asks only what is left: period and frequency, reuse of an earlier assessment, notification.
3. 52 percent is level III; 50 percent is still level II, because the band runs up to and including 50.
4. An Annex III area, and significant decisions made by the system on its own. Both lift the level to III so the rights, complaint, explanation and automation bias questions are asked where they matter most.
5. The level is set from the intake, before mitigations are asked. Mitigations show in the residual rating of the Impact step instead.
6. Yes. Five GenAI questions (input filtering, vector store, rate limits, threat model, energy) show at every level for a public-facing system.
7. Only when the AI Act module is closed. With an EU nexus, Article 50 owns transparency and the GenAI disclosure value is derived from it.
8. Yes. Profiling of natural persons keeps an Annex III system high-risk whatever Article 6(3) condition applies.
9. The copyright policy and the training content summary. The two documentation duties of Article 53(1)(a) and (b) and the authorised representative do not apply, unless the model has systemic risk.
10. From 2 August 2026. Providers of synthetic content generators already on the market before then have until 2 December 2026 to meet the marking duty of Article 50(2).
11. One line at medium, tagged with the owner of the question and 'also' the other part, listed against every framework entry its questions map to.
12. No. That dimension is mostly for governments and model developers; for a deployer it usually stays Not assessed, and Not assessed is never read as a pass or a fail.
13. The pathway rates interference with rights; the DPIA rates harm from the processing. Same bands, different object, and a pre-filled rating tends to go unexamined.

14. The impact level measures how much the system could affect people, from the intake. The overall level is the worst finding: how well the risks are controlled. A level I system can have a High finding.
15. Only the EU AI Act is law. ISO/IEC 42001 and 42005 are voluntary and cited by number and title only, because their texts are paid.

11. Sources

- Regulation (EU) 2024/1689 (AI Act) as amended by Regulation (EU) 2026/1744: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj> and <https://eur-lex.europa.eu/eli/reg/2026/1744/oj> ; article summaries in the site's AI Act Digest (<ai-act-digest.html>).
- NIST AI 100-1, AI Risk Management Framework 1.0 (January 2023): <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> ; revision status: <https://www.nist.gov/itl/ai-risk-management-framework>
- NIST AI 600-1, Generative AI Profile (July 2024): <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- Government of Canada, Algorithmic Impact Assessment tool: <https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/algorithmic-impact-assessment.html> ; Directive on Automated Decision-Making (as amended 24 June 2025): <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592>
- ISO/IEC 42005:2025, AI system impact assessment: <https://www.iso.org/standard/42005>
- ISO/IEC 42001:2023, AI management system: <https://www.iso.org/standard/42001>
- AI Verify Foundation and IMDA, Model AI Governance Framework for Generative AI (30 May 2024): <https://aiverifyfoundation.sg/resources/mgf-gen-ai/>
- OWASP Top 10 for LLM Applications (2025): <https://genai.owasp.org/llm-top-10/>
- MITRE ATLAS: <https://atlas.mitre.org/>
- The site's AI Governance Crosswalk (<ai-governance-crosswalk.html>): the obligation rows the AI Act module links to.